

Rahasya implementation spec for Claude Code

Oct 1, 2026 · @Kumar

How to use this spec

This is the single build spec for Rahasya: Claude Code builds every screen, rule and endpoint from it, and treats it as the source of truth when it disagrees with older material. Export it as Markdown into the repository as `docs/SPEC.md` and point `CLAUDE.md` at it.

Sources behind it (read them for background; this spec wins on conflict):

Source	Use it for
Rahasya PRD	Requirements FR-01 to FR-40 and their priorities
Rahasya design document	Design rationale, sections 10 to 12
Rahasya build plan	Sprints, hosting, testing, risks
Rahasya screens	Static mockups of every screen in the three themes
Rahasya motion library	Every animation playing live, phone and web, including the admin console; match its timing

Rules for Claude Code

1. Build in the order of the task list at the end; never start a screen before the crypto core and API it calls pass their tests.
2. Use only the tokens in the design tokens section; no hard-coded colours, sizes or durations in screen code.
3. Plaintext secrets, master passwords and keys never leave `packages/crypto` on the device: never log them, send them, or store them unencrypted.
4. Every screen ships with its loading, empty and error states, all three themes, reduced motion, and screen-reader labels.
5. When this spec is silent, follow the nearest screen that is specified and leave a `TODO(spec)` comment; never invent new features.

Definition of done for a screen: it matches its mockup in all three themes at 390 px (phone) or 1440 px (web), every acceptance criterion in its table passes, its animation matches the motion library within 50 ms, and its tests run in CI.

Product rules and fixed numbers

Rahasya is a zero-knowledge password manager: one person per account, signed in on several devices (Android and web), each with a private vault; no shared vaults in v1. Put every number below in one `packages/config` module so screens and the API read the same values.

Rule	Value	Where it shows	PRD
Revealed password re-hides	20 s	Entry detail, desktop detail	FR-03
Clipboard auto-clear after copy	30 s	Clipboard pill	FR-04
Auto-lock when idle	5 min (setting: 1 to 60 min); also on app background and hidden browser tab	Lock screen	FR-17
Wrong master password lockout	After 5 tries, wait 30 s	Unlock	FR-02
Unlock time after Argon2id	Under 1.5 s on a mid-range phone	Unlock	FR-02
Sync delay between devices	Under 5 s when online; newest revision wins, older kept in history	Home, desktop list	FR-16
Password history	Last 10 versions per entry	Detail, edit	FR-22
Removed fields and edit history	Kept 30 days	Edit, history	FR-34
Undo after delete	5 s toast; Trash keeps entries 30 days	Toast, Trash	FR-35
Group nesting	Up to 3 levels; groups only in the drawer or sidebar	Drawer, sidebar	FR-06, FR-32
Recovery waiting period	48 h (setting: 0 to 7 days); user can cancel	Admin A4	FR-29
Admin session	15 min; hardware security key required; IP allow-list	Admin A1	FR-25
Super admin	Exactly one; never deleted, demoted or suspended	Admin A5	FR-40

Rule	Value	Where it shows	PRD
Health score	0 to 100	Security health	FR-20
Skippable animation	Anything over 1 s; quicker version (about 60% length) after 3 plays	Everywhere	FR-38
Reduced motion	Final frame with a 200 ms fade	Everywhere	FR-38
Frame rate	60 fps on a mid-range Android phone	Everywhere	FR-38
Contrast	At least 4.5:1 in all three themes	Everywhere	FR-24
Touch targets	At least 44 by 44 px	Everywhere	NFR

Repository, stack and routes

One private GitHub repository (pnpm workspaces and Turborepo) holds three apps and six shared packages; everything runs on free tiers.

rahasya/	
apps/	
app/	Expo (React Native + Web), Expo Router: Android APK and vault
web app	
admin/	Next.js (App Router): admin console, own domain, strict CSP
api/	NestJS + Prisma: auth, vault sync, admin, audit
packages/	
crypto/	libsodium wrappers: Argon2id, HKDF, XChaCha20-Poly1305,
sealed boxes	
tokens/	theme JSON (D9, D10, D14, Admin) -> TypeScript + CSS
variables	
ui/	shared components (see Shared components)
motion/	Reanimated 3 + React Native Skia animation primitives
api-client/	typed client, retries, sync queue
config/	the fixed numbers from Product rules
docs/SPEC.md	this document

Area	Choice
App	Expo SDK (latest stable at setup), Expo Router, TypeScript strict
Crypto	react-native-libsodium on Android, libsodium-wrappers-sumo on web

Area	Choice
Animation	Reanimated 3, React Native Skia; on web, Skia via CanvasKit
Storage	Android Keystore via expo-secure-store; web IndexedDB with a non-extractable WebCrypto wrapping key
Privacy	expo-screen-capture (FLAG_SECURE), blur in the app switcher
Unlock	expo-local-authentication (Android); WebAuthn passkey (web)
API	NestJS, Prisma, class-validator, Postgres
Admin	Next.js App Router, server-rendered, WebAuthn security keys
Tests	Vitest, Jest, Detox (Android), Playwright (web), Storybook
Hosting	Vercel Hobby (web, admin), Render free web service (API), Neon free tier (Postgres), GitHub Actions and Releases

Routes, vault app (Expo Router; the same routes drive the phone and web layouts):

Route	Screen	Signed in	Unlocked
/welcome	Welcome	No	No
/signup , /signup/recovery	Create account, recovery kit	No	No
/signin	Sign in (email, master password, 2FA code)	No	No
/unlock	Unlock (S1)	Yes	No
/	Home (S2) on phone; three-pane vault on web	Yes	Yes
/group/[id]	Home filtered by group (drawer S3 on phone, sidebar on web)	Yes	Yes
/entry/[id]	Entry detail (S4)	Yes	Yes

Route	Screen	Signed in	Unlocked
/entry/new	Add entry (S5)	Yes	Yes
/entry/[id]/edit	Edit entry (S9), add field (S10), save (S11)	Yes	Yes
/generator	Generator (S6)	Yes	Yes
/health	Security health (S7)	Yes	Yes
/settings	Settings (S8)	Yes	Yes
/trash	Trash	Yes	Yes

Routes, admin console (Next.js; phone and desktop layouts from the same pages):

Route	Screen	Permission
/signin	A1 Sign in	None
/users	A2 Users	Manage users or view users
/recovery , /recovery/[id]	A4 Recovery requests and detail	Start recovery
/audit	A3 Audit log	View audit log
/admins	A5 Admins and roles	Manage admins (view for others)
/policies , /settings	Policies, settings	Owner or super admin

Design tokens

All screens use one set of token names with four value sets: D9 Glass wallet (dark), D10 Daylight glass bento (light, default by day), D14 Holographic bento (dark), and Admin (fixed light, admin console only). Auto mode uses D10 by day and D9 or D14 at night, as the user chooses.

Colour

Token	D9 Glass wallet	D10 Daylight	D14 Holographic	Admin
bg	#0B0A1A + aurora #6B4CFF, #14B8A6, #F472B6	#F5F3FA + aurora #B9A6FF, #FFB38A, #8EE3C8	#07070A + glow #B388FF at 16%	#F6F5FA + aurora #B9A6FF, #FFB38A at 30%
text	#F4F2FF	#1E1B2E	#F4F4F6	#1E1B2E
text- muted	#C9C4E8	#6B6780	#9A9AA6	#6B6780
accent (gradient)	#6B4CFF to #F472B6, 135°	#8B6CFF to #FF9A6B, 135°	#7CF7FF, #B388FF, #FF8AD8, #FFE08A, 120°	#8B6CFF to #FF9A6B
accent- solid	#C4B5FD	#6B4CFF	#7CF7FF	#6B4CFF
on- accent	#FFFFFF	#FFFFFF	#07070A	#FFFFFF
soft	rgba(255,255,255,.14)	rgba(255,255,255,.85)	#1E1E26	rgba(30,27,46,.06)
selected	rgba(255,255,255,.16)	rgba(139,108,255,.14)	#1E1E26	rgba(139,108,255,.12)
warning	#FBBF24	#B45309	#FFE08A	#B45309 (amber, privileged actions)
danger	#F9A8D4	#BE185D	#FF8AD8	#BE185D
danger- soft	rgba(249,168,212,.16)	rgba(190,24,93,.10)	rgba(255,138,216,.14)	rgba(190,24,93,.10)
success	#6EE7B7	#15803D	#7CF7FF	#15803D

Surfaces

Token	D9	D10	D14	Admin
surface (glass card)	linear 135° rgba(255,255,255,.20) to .06; border 1px rgba(255,255,255,.22); blur 20px, saturate 1.6	rgba(255,255,255,.55); border 1px rgba(255,255,255,.85); blur 20px; shadow 0 12px 30px -14px rgba(80,60,140,.30)	#121217 with a 1.5px holographic gradient border; no blur	rgba(255,255,255,.84); border 1px rgba(30,27,46,.08); shadow 0 1px 2px rgba(30,27,46,.04), 0 12px 32px -20px rgba(60,40,120,.28)
orb-glow	rgba(107,76,255,.45)	rgba(139,108,255,.35)	rgba(179,136,255,.35)	as D10
orb-spec (highlight)	white at 50%	white at 90%	white at 20%	as D10
orb- shadow	inset 0 1px 0 rgba(255,255,255,.45), inset 0 -16px 34px rgba(0,0,0,.28), 0 22px 44px -18px rgba(0,0,0,.5)	inset 0 1px 0 rgba(255,255,255,.9), inset 0 -16px 34px rgba(80,60,140,.14), 0 22px 44px -18px rgba(80,60,140,.4)	inset 0 1px 0 rgba(255,255,255,.25), inset 0 -16px 34px rgba(0,0,0,.45), 0 22px 44px -18px rgba(0,0,0,.6)	as D10

The glass orb is a 140 to 150 px circle with `surface` , `orb-shadow` , a soft `orb-glow` 22 px outside it (blurred 10 px), a specular ellipse (62% by 42% at 34%, 20%) in `orb-spec` , and the keyhole filled with the accent gradient and a 2 px drop shadow. Keyhole path (viewBox 0 0 44 60): `M22 4 A14 14 0 0 1 28 30.6 L33 56 L11 56 L16 30.6 A14 14 0 0 1 22 4 Z` .

Type, spacing and shape

Token	Value
Heading font	Outfit 600 (D9, D14); Sora 600 (D10, Admin); D14 headings filled with the holographic gradient
Body font	Same family, 400
Secret font	DM Mono 500: passwords, codes, cipher text, timers
Type scale (px)	11 caption, 12 meta, 13 label, 14 to 15 body, 16 to 17 button, 20 to 24 title, 26 to 34 page title
Spacing (px)	4, 8, 12, 16, 20, 24, 32, 48; phone side margin 20, web margin 24, section gap 16
Radius (px)	12 icon chip, 16 to 18 field and list row, 20 to 24 card and tile, 27 to 30 input, 28 sheet and wallet card, 32 drawer, pill for buttons and chips
Phone nav bar	Floating glass bar, 64 to 68 px tall, radius 32 to 34, 20 px from the bottom

Token	Value
Drawer	318 px wide, slides from the left over a scrim
Web panes	Sidebar 264 px, list 400 px, detail fills the rest, 16 px gaps, 20 to 24 px outer margin

Shared components

Build these in `packages/ui` first, each with a Storybook story in all three themes plus Admin where used; screens are assembled only from them.

Component	Key props	States	Used on
<code>GlassSurface</code>	<code>variant</code> : tile, card, sheet, pill; <code>selected</code>	default, pressed (scale 0.95, spring back 350 ms), selected	Everywhere
<code>GlassOrb</code>	<code>size</code> , <code>keyholeFlash</code> : none, white, red	idle, flashing	Splash, unlock, lock, add, update
<code>OrbitRings</code>	<code>mode</code> : draw, close, flatten, strain, spin; <code>color</code>	see Motion	Splash, unlock, wrong password, lock, add, update, sync
<code>CipherText</code>	<code>value</code> , <code>mode</code> : scramble, decrypt, encrypt, <code>stepMs</code>	plain, scrambling, settled	Splash, reveal, regenerate, add, update, delete
<code>GradientUnderline</code>	<code>mode</code> : draw, countdown, error; <code>durationMs</code>	idle, running, done	Reveal, copy, regenerate, wrong password, delete toast
<code>SecretField</code>	<code>label</code> , <code>value</code> , <code>kind</code> : password, pin, totp, text; <code>onCopy</code> , <code>onReveal</code>	masked, revealed (auto-hide), copied	Detail, desktop detail
<code>FieldRow</code>	<code>label</code> , <code>value</code> , <code>state</code> : same, edited, new, removing; <code>required</code>	each state with its marker; Undo on removing	Edit (S9), desktop edit

Component	Key props	States	Used on
AddFieldPicker	entryType, onPick	8 type tiles + suggestions	Sheet (phone S10), popover (web)
EntryRow	entry, selected, label	default, selected (tint + 3 px accent bar), updated (shimmer), new (glow)	Home list, desktop list
WalletCard	entry, stackIndex	stacked, lifted	Home on D9
BentoTile	kind: health, generator, recent, labels	default, pressed	Home on D10, D14
GroupTree	groups, selectedId, maxDepth = 3	collapsed, expanded, selected	Drawer (S3), web sidebar
LabelChips	labels, selected[]	off, on	Home filter, drawer, sidebar
StrengthMeter	score 0 to 4, variant: ring, bar	weak to very strong	Generator, add, edit, health
Toast	title, subtitle, action (Undo), countdownMs	entering, shown, leaving	Copy, delete, save, sync
ClipboardPill	clearsInMs	copied (countdown), cleared	Copy (M3)
FloatingNavBar	items, active, badge	default, active tab	Phone app, phone admin
SegmentedControl	options, value	default, selected	Settings (Light, Dark, Auto), filters
ThemeSwatch	theme, selected	default, selected (2 px ring, 3 px offset)	Settings (M8)
AdminTable	columns, rows, rowTint	header row tinted, edge-to-edge rows, last row without divider	Admin web

Component	Key props	States	Used on
StepTimeline	steps with done, now, next	no line after the last step	Admin recovery
RoleChip, StatusChip	role or status	Super admin chip = accent gradient with a lock	Admin

Motion

Every animation is built from the primitives in `packages/motion` and must match the [motion library](#) within 50 ms. Each one has one hero moment and uses only the brand elements: glass orb, three orbit rings, cipher text, gradient underline, keyhole.

Easing and primitives

Name	Value
Ease out (entrances)	cubic-bezier(.2,.8,.2,1)
Ease in-out (morphs)	cubic-bezier(.65,0,.35,1)
Spring (pops, badges)	cubic-bezier(.3,1.3,.5,1)
Entrance	Rise 16 to 24 px with fade, 500 to 600 ms, 50 to 90 ms stagger
Orbit rings	Three ellipses rx 92 to 108, ry 32 to 38, at 0°, 60°, 120°; draw 0.5 s; turn 200 to 220° then scaleY 2.8 to close into a circle
Cipher decrypt	All characters scramble, then lock left to right 45 ms apart (splash: 180 ms); glyph set <code>#\$%&@*?!ΣΞΛ0-9A-Z a-z</code>
Shockwave ring	Starts invisible: scale 0.8 to 2.1, opacity 0 to 0.7 to 0 over 700 ms
Haptics (Android)	Light tick on success; double tap on M2o

The 13 approved animations

Code	Moment	Timeline	Total
SP14	Splash	0.1 s rings draw around the glass name plate; 0.3 s letters scramble; 0.8 s letters decrypt 180 ms apart into "Rahasya"; 2.0 s rings flatten into an underline; 2.0 s keyhole pops above; 2.3 s "Decrypted, just for you." rises	2.6 s first launch, 1.2 s daily
M1	Unlock (fingerprint or passkey)	0.35 s touch; 0.5 s rings draw and turn; 1.3 s rings close, keyhole flashes white; 1.45 s iris opens from the orb to the vault; 1.6 s vault rises	about 2 s
M2o	Wrong master password	Same as M1 until 1.0 s; rings strain (scaleY 1.35) and spring back, fading; 1.1 s keyhole flashes red; 1.25 s field clears; 1.3 s red underline grows; 1.4 s message "Incorrect master password, N tries left"	1.5 s
M7	Auto-lock	0.5 s vault closes inward in a circle to the orb centre (0.7 s); 0.9 s orb appears; 1.0 s rings draw and close; 1.6 s "Locked"	about 2 s
M3	Copy	Copy icon becomes a check (0.3 s); dots flicker to cipher and back (0.45 to 0.7 s); clipboard pill slides down from the top (0.45 s) with an underline counting 30 s; then "Clipboard cleared"; pill leaves	0.5 s + 30 s
M4	Reveal	Eye becomes eye-off; dots scramble then decrypt 45 ms apart; underline counts 20 s; then characters scramble back to dots right to left, 28 ms apart	1 s + 20 s
M5a	Open entry	Card lifts 4 px and scales 1.02 (0.2 s); grows into the page (0.55 s); icon and name glide into the header; list fades. Web: selection glides to the row; the icon lifts from the list into the detail header	0.75 s

Code	Moment	Timeline	Total
A11	Add entry	0.5 s save; fields outline and scramble (60 ms apart); 1.1 s orb pops, rings turn, "encrypting 0 to 100%"; 1.15 s fields stream into the orb (70 ms apart); 2.05 s keyhole; 2.45 s orb morphs into the card; 2.85 s shockwave and "Encrypted and sealed"; 3.45 s card flies into its list position, which glows	about 4 s
U4	Update entry	Unchanged fields dim to 22%; changed and new fields scramble and stream into the orb 90 ms apart (max 5); removed fields strike through and dissolve; "re-encrypting N changes"; orb morphs into the card with change chips (pencil, plus, minus; max 3 then "+N more") and a version badge; card settles into the detail header; Updated and Added badges glow in turn; only removals skip the orb	4 to 4.5 s
M6	Delete	Swipe (phone) or hover button (web) reveals Delete; row text turns to cipher and fades (0.4 s); rows below close the gap; toast with Undo and a 5 s underline	1.2 s + 5 s
M9	Regenerate	Refresh icon turns once; all characters scramble, then lock left to right 40 ms apart; underline redraws	1 s
M8	Theme switch	The new theme spreads in a circle from the tapped swatch	0.75 s

Code	Moment	Timeline	Total
M10	Sync	Phone: pull reveals the orb, rings draw with the pull, spin while syncing, resolve to a check, then the indicator fades as the list springs back. Web: the sync button starts it and a status chip shows the same. Updated rows shimmer with an Updated badge	about 2.8 s

Admin console screens use the same primitives: sign-in plays M1 with a security key; confirming a recovery spins the rings inside the button.

Vault app on phone

Reference frame 390 by 844 px; every screen exists in D9, D10 and D14, and its mockup is on the Final page of [Rahasya screens](#). Screens marked "no mockup" are built from the shared components in the same style.

Splash (SP14)

- **Layout:** centred glass name plate (300 by 96 px, radius 34) with "Rahasya", keyhole above, orbit rings around, tagline below.
- **Behaviour:** plays SP14 on cold start; full version on first launch and after updates, short version otherwise; then routes to Welcome, Unlock or Home.
- **Done when:** it never blocks longer than 2.6 s and is skippable with a tap.

Welcome, sign up, sign in (no mockup)

- **Welcome:** glass orb, "Rahasya", "Your secrets, safely yours.", primary "Create account", secondary "Sign in".
- **Create account:** email; master password with `StrengthMeter` (minimum 12 characters and "strong"); confirm; a warning that the master password cannot be reset by anyone unless the account belongs to an organisation with recovery; then key derivation with a progress line; then a printable recovery kit (email, server address, safety tips) and optional two-step sign-in setup.
- **Sign in:** email, master password, 6-digit code when two-step sign-in is on; success plays M1, failure plays M2o.
- **Done when:** no plaintext password leaves the device; the server receives only the authKey hash input (see Encryption).

S1 Unlock

- **Layout:** glass orb (150 px) centred in the upper half with its gradient ring; "Welcome back" and the name below; fingerprint button (64 px) with "Touch to unlock"; link "Use master password" reveals a field and an Unlock button.
- **Behaviour:** success plays M1 and opens Home; a wrong password plays M2o; after 5 failures the red underline becomes a 30 s countdown.
- **Done when:** unlock completes in under 1.5 s after Argon2id on a mid-range phone; fingerprint falls back to the master password.

S2 Home

- **Layout:** greeting and avatar; menu button (opens S3) and "+" (opens S5); search field; label chips; sort control (Name A to Z, Z to A, Date newest, oldest); then the list. D9 shows stacked `WalletCard` s; D10 and D14 show `BentoTile` s (health ring, generator, recent entries) above the list. Floating nav bar: Home, Generator, Health, Settings.
- **Behaviour:** tap opens S4 with M5a; copy on the row copies the password (M3); pull down syncs (M10); swipe left reveals Delete (M6). Groups never appear here.
- **Done when:** sort applies to entries and to group order in the drawer (FR-33); empty state invites adding the first entry.

S3 Group drawer

- **Layout:** 318 px panel from the left over a scrim; All items with count; `GroupTree` (3 levels, colour dot, count); label chips; Trash link. No sort control.
- **Behaviour:** springs in (600 ms); choosing a group filters Home and closes the drawer.

S4 Entry detail

- **Layout:** back, favourite, more (Edit, Password history, Delete); hero icon, name, group path, labels; `SecretField` rows with eye and copy side by side; one-time code with its 30 s ring; notes; password history link.
- **Behaviour:** reveal plays M4 and hides after 20 s; copy plays M3 without revealing; screenshots blocked (FLAG_SECURE).
- **Done when:** every hidden field supports copy-without-reveal and auto-hide.

S5 Add entry

- **Layout:** Cancel, "New login"; template chips Login, Bank, Card, Wi-Fi, Secure note; the template's fields; Generate on the password field with a strength bar; group and labels pickers; "Save to vault".

- **Templates:** Login (name, username, password, website, notes); Bank (bank, customer ID, account number, net-banking username, password, transaction PIN); Card (name, cardholder, number, expiry, CVV, PIN); Wi-Fi (network, password, security type); Secure note (title, note).
- **Behaviour:** Save plays A11 and lands the new entry in Home.

S6 Generator

- **Layout:** large password in DM Mono with digits and symbols in `accent-solid`; strength ring and "centuries to crack"; refresh; length slider (8 to 64, default 18); toggles for upper and lower case, digits, symbols, avoid look-alikes; Copy and Use password.
- **Behaviour:** refresh plays M9; generation is cryptographically random on the device.

S7 Security health

- **Layout:** score ring (0 to 100) with count-up; tiles for weak, reused, older than a year, and breached (shown when breach checks arrive in Phase 2); "Fix these first" list with Change or Review.
- **Behaviour:** computed on the device from decrypted entries; nothing sent to the server.

S8 Settings

- **Layout:** profile card; Theme: three `ThemeSwatches` and `SegmentedControl` Light, Dark, Auto (with the night theme choice); Security: fingerprint unlock, ask before revealing, auto-lock time, clear clipboard (30 s), screenshot protection; Account: devices (sign out a device), two-step sign-in, change master password, sign out.
- **Behaviour:** tapping a swatch plays M8; the theme is remembered per device.

S9 Edit entry

- **Layout:** "Edit login" with a count of unsaved changes; `FieldRows` with drag handle; Required on name, username and password; minus button on others; "Add field" dashed pill; Save changes.
- **Behaviour:** tap a value to edit (Edited marker); minus marks "Will be removed" with Undo until save; changing a value back clears its marker; Save with no changes shows "Nothing to save yet".

S10 Add field (sheet)

- **Layout:** bottom sheet with 8 types (Text, Secret, PIN, Link, Email, 2FA code, Note, Date), each marked Hidden or Visible, plus suggestions for the entry type (banking: Transaction PIN, Customer ID, Security answer, Recovery code).
- **Behaviour:** the new field unfolds into the list with a dashed outline and a New tag.

S11 Save changes

- **Behaviour:** plays U4; then S4 shows Updated and Added badges; a toast summarises ("1 updated, 1 added, 1 removed").

Trash (no mockup)

- **Layout:** deleted entries with days left (out of 30), Restore, and Delete forever with a confirmation.
- **Done when:** entries purge automatically after 30 days and restore exactly as they were.

Vault app on desktop web

The same Expo app renders a three-pane layout at 1440 by 900 px reference; mockups are on the Desktop web page of [Rahasya screens](#) and every web animation plays under Web in the motion library.

Shell

Pane	Width	Contents
Sidebar	264 px	Mini orb and name; search (Ctrl K); All items, Favourites, Security health, Generator, Settings; groups tree (3 levels, colour dot, count); labels; profile and lock button
List	400 px	Title and count; sync button; New; type filters (All, Logins, Cards, Notes); sort control; EntryRow s; selected row tinted with a 3 px accent bar
Detail	Rest	Group path; Edit, favourite, more; icon, name, change date, version; field rows (label column 150 px, value, eye, copy, open); one-time code with 30 s ring; security summary with password history

Breakpoints: at least 1200 px shows all three panes; 900 to 1199 px collapses the sidebar to icons; under 900 px uses the phone layout and routes.

Keyboard: Ctrl K search, up and down move through the list, Enter opens, C copies the password, E edits, Esc closes popovers and dialogs. Every control is reachable by Tab with a visible focus ring.

Screens and their web behaviour

Screen	Web layout	Animation
Splash	Centred on the aurora, scaled 1.4	SP14
Unlock	Centred column: orb, "Welcome back", master password field (420 px), Unlock, "Use passkey" (WebAuthn)	M1 opens into all three panes; M2o on failure
Vault (home)	Three panes, first entry selected	Panes rise 80 ms apart
Filter by group	Sidebar group highlight moves; list title and rows change	Old rows fade, matching rows rise 50 ms apart
Open entry	Detail pane shows the entry	M5a web: selection glides, icon lifts into the header
Reveal and copy	In the detail pane	M4; M3 with the pill centred at the top of the window
Add entry	Detail pane becomes the form; Save at the pane's foot	A11; the card flies from the pane to its list position
Edit entry	Detail pane in edit mode with Cancel and Save changes	Same states as S9
Add field	Popover (560 px) anchored under "Add field" with 8 types in a 4 by 2 grid and suggestions	Scale-in from the anchor
Save changes	Inside the detail pane	U4; the card settles into the detail header; toast at the bottom centre
Delete	Hover shows a delete button on the row; detail shows "Nothing selected"	M6; toast at the bottom centre
Sync	Sync button in the list header; status chip under it	M10 web

Screen	Web layout	Animation
Generator	Main area next to the sidebar; recently generated list on the right	M9
Security health	Main area: score ring, four tiles, fix list	Ring draws, score counts up
Settings	Main area: theme card (swatches, Light, Dark, Auto), security toggles, profile	M8 from the swatch across the window
Auto-lock	After 5 min idle or when the tab is hidden	M7 centred on the window

Admin console on phone and web

A separate Next.js app on its own domain with the fixed Admin theme; amber marks privileged actions. Admins manage accounts but can never read a vault. Desktop mockups are on the Admin console page of the canvas, and both phone and web versions play under "Admin console" in the motion library.

Layouts: web has a 240 px sidebar (Users, Recovery with a count badge, Audit log, Admins and roles, Policies, Settings; profile at the foot) and a 56 px top bar (title, subtitle, search, main action), 24 px margins and 16 px gaps. Phone uses a floating bottom bar (Users, Recovery with a badge, Audit, Settings) with Admins and roles under Settings, 20 px margins, and lists grouped in one card with dividers.

Screen	Phone	Web	Done when
A1 Sign in	Orb, "Rahasya Admin", work email, master password, "Security key" field; Continue	Same in a centred 440 px card under the orb	A hardware security key is required; touching it plays M1 and opens Users; session lasts 15 min; IP allow-list enforced
A2 Users	2 by 2 tiles that count up (users, active today, two-step coverage, recovery requests); filters All, Locked, Invited, No 2FA; user list card	Four tiles in a row; edge-to-edge table: user, status, 2FA, emergency access, last active, vault items, menu	A pending recovery shows as an amber-tinted row; invite, lock, suspend and reset two-step act from the row menu

Screen	Phone	Web	Done when
A3 Audit log	"Log chain verified" chip, filters, events grouped by day; title on line one, actor, time and result chip on line two	Filters with the verified chip on the right; table: time, who, action, target, device, result	Emergency events tinted amber; the chain check verifies every entry's hash; export works
A4 Recovery	Request card with reason; four-step timeline; "Confirm with passkey" and Cancel request above the nav	Timeline card with footer actions; safeguards and "The server cannot decrypt" stacked on the right	One admin confirms with a security key or passkey, which starts the 48 h wait; live countdown; Recover stays disabled until the wait ends; the user is notified and can cancel
A5 Admins and roles	Admins card (name, You, key status, role chip) and roles card; "+" opens an Add admin sheet	Admins table and roles card; "Add admin" opens a 440 px dialog	Only the super admin and Owners can add or change admins; invited admins show "Key pending"; the super admin row shows a lock instead of a menu

Roles and permissions (custom roles pick from the same permissions):

Permission	Super admin	Owner	Admin	Auditor
View users	Yes	Yes	Yes	Yes
Manage users (invite, lock, suspend, reset 2FA)	Yes	Yes	Yes	No
Start and confirm recovery	Yes	Yes	Yes	No
Urgent decrypt (escrow organisations, Option C)	Yes	Yes	No	No
View audit log	Yes	Yes	Yes	Yes
Manage admins and roles	Yes	Yes	No	No
Hand over the super admin role	Yes	No	No	No

Super admin rules: exactly one, created by the setup server command; stored as a protected flag, not a role, so the API answers 403 to any delete, demote, suspend or lock; only the super admin can hand the role to another admin, confirmed with their own security key, and then becomes an Owner; a break-glass server command (run on the server with the offline key) can reset a lost key or freeze the account but never delete it; every change is logged and all Owners are notified. Urgent decrypt of all users asks the admin to type the organisation name to confirm.

Encryption

All encryption happens in `packages/crypto` on the device with libsodium; the server stores only a hash of the authKey, wrapped keys and ciphertext. The [build plan](#) draws the key hierarchy.

Key derivation and use

1. Sign-up: generate a 16-byte random salt; store Argon2id settings per user (start at 64 MiB memory, 3 passes, parallelism 1; tune so it takes about 0.5 s on a mid-range phone).
2. `masterKey` = Argon2id(master password, salt), 32 bytes.
3. HKDF-SHA-256 splits it: `authKey` = HKDF(masterKey, info "rahasya-auth"), `wrapKey` = HKDF(masterKey, info "rahasya-wrap"), 32 bytes each.
4. `authKey` is sent at sign-in; the server stores only Argon2id(authKey) with its own salt and compares in constant time.
5. `vaultKey` = 32 random bytes, created once at sign-up; stored on the server only as XChaCha20-Poly1305(wrapKey, vaultKey).
6. Every item, group name and label is encrypted with vaultKey using XChaCha20-Poly1305 and a fresh 24-byte random nonce on every save.
7. Changing the master password re-wraps vaultKey only; items are never re-encrypted.
8. Recovery (Option B): vaultKey is also sealed (X25519 sealed box) to the organisation's offline public key when the user opts in. Escrow (Option C, off by default): vaultKey is also wrapped by a KMS key.
9. On device, the wrapped vaultKey is cached in the Android Keystore (expo-secure-store) or under a non-extractable WebCrypto key in IndexedDB; fingerprint or passkey unlock releases it.

Ciphertext format (every blob):

Bytes	Field
1	Version, 0x01

Bytes	Field
1	Algorithm id, 0x01 = XChaCha20-Poly1305
24	Nonce
n	Ciphertext
16	Authentication tag

Rules: keys are zeroed after use and never logged, including in debug builds and crash reports; a changed byte anywhere must fail decryption, never return garbage; fixed test vectors must give byte-identical results on Android and web; no custom crypto beyond these libsodium calls.

API and database

The NestJS API syncs ciphertext and manages accounts; no endpoint accepts or returns plaintext secrets. All requests use HTTPS and JSON; vault endpoints need a short-lived JWT plus a rotating refresh token.

Area	Endpoints	Notes
Sign-up and sign-in	POST /auth/register, POST /auth/prelogin, POST /auth/login, POST /auth/refresh, POST /auth/logout	Prelogin returns salt and Argon2id settings; login checks the authKey hash; 5 failures then a 30 s wait per account; IP rate limits
Two-step sign-in	POST /auth/2fa/setup, POST /auth/2fa/verify	TOTP; rate-limited
Vault	GET /vault/sync?since=, PUT /vault/items/:id, DELETE /vault/items/:id, POST /vault/items/:id/restore	Encrypted blob plus revision; newest revision wins and the older one goes to history; delete moves to Trash for 30 days
Groups and labels	GET/PUT /vault/groups, GET/PUT /vault/labels	Names encrypted; groups up to 3 levels
Devices	GET /devices, DELETE /devices/:id	Sign out a lost device

Area	Endpoints	Notes
Admin users	GET /admin/users , POST /admin/users/:id/lock , POST /admin/users/:id/suspend , POST /admin/users/:id/reset-2fa , POST /admin/invites	Permission-checked; separate origin
Recovery	POST /admin/recovery , POST /admin/recovery/:id/confirm , POST /recovery/:id/cancel	Confirm needs a WebAuthn assertion and starts the 48 h wait; the user can cancel
Admins and roles	GET/POST /admin/admins , PATCH/DELETE /admin/admins/:id , GET/POST/PATCH /admin/roles , POST /admin/super/handover	Super admin and Owners only; any change to the super admin returns 403 except handover by the super admin
Audit	GET /admin/audit , GET /admin/audit/verify , GET /admin/audit/export	Read-only; hash-chained

Table	Holds
users	Email, salt, Argon2id settings, authKey hash, wrapped vaultKey, encrypted 2FA secret, status
vault_items	User, item id, encrypted blob, revision, deleted_at (Trash), timestamps
item_history	Previous encrypted versions (last 10, kept 30 days)
groups , labels , item_labels	Encrypted names, parent group, links
devices , refresh_tokens	Signed-in devices and token rotation
recovery_keys	vaultKey sealed for recovery (Option B) or escrow (Option C)
recovery_requests	Requester, reason, confirmed_at, waiting-period end, status (pending, confirmed, cancelled, used)
admins	Admin account, security keys (WebAuthn credentials), role, is_super protected flag
admin_roles	Name, permission list, built_in flag, created_by
audit_log	Actor, action, target, device, IP, result, time, hash of the previous entry

Breaking schema changes are not allowed: every Prisma migration stays backward compatible for one release, and runs before the new API starts.

Task list for Claude Code

Work through the sprints in order; each task is one pull request with tests, and a sprint ends only when every task passes CI. Dates follow the build plan: four-week sprints from 5 October 2026 to the public beta on 16 April 2027.

S0 Repository and tokens (5 to 30 Oct 2026)

- ☐ Monorepo with `apps/app`, `apps/admin`, `apps/api` and the six packages; TypeScript strict, ESLint, Prettier
- ☐ CI on GitHub Actions: lint, type check, tests, Vercel previews; CodeQL, Semgrep and npm audit
- ☐ `packages/tokens` from the Design tokens section, generating TypeScript and CSS variables
- ☐ `packages/config` with every number from Product rules
- ☐ ThemeProvider with Light, Dark, Auto and the no-flash web script
- ☐ Storybook with `GlassSurface` and `Glass0rb` in all themes

S1 Crypto core and auth (2 to 27 Nov)

- ☐ `packages/crypto` : Argon2id, HKDF, XChaCha20-Poly1305, ciphertext format, sealed boxes, zeroing
- ☐ Shared test vectors passing byte-identical on Android and web
- ☐ API auth: register, prelogin, login, refresh, logout, 2FA, rate limits and logout
- ☐ Screens: Splash, Welcome, sign up, sign in, S1 Unlock with M1 and M2o

S2 Vault API and sync (30 Nov to 25 Dec)

- ☐ Vault, groups, labels, devices, Trash and history endpoints with Prisma schema
- ☐ `packages/api-client` with a sync queue, offline edits and newest-revision merge
- ☐ Two-device sync test (Android plus web)

S3 Phone screens, internal alpha (28 Dec to 22 Jan 2027)

- ☐ All shared components in `packages/ui` with stories
- ☐ S2 to S11 and Trash on real data, in all three themes
- ☐ FLAG_SECURE, app-switcher blur, clipboard clearing, auto-lock

S4 Desktop web and motion (25 Jan to 19 Feb)

- ☐ Three-pane shell, breakpoints and keyboard shortcuts
- ☐ Every web screen variant from the desktop table
- ☐ `packages/motion` primitives and all 13 animations on phone and web, checked against the motion library
- ☐ Reduced motion, tap to skip, quicker version after 3 plays, haptics

S5 Admin console and recovery (22 Feb to 19 Mar)

- ☐ Admin app with Admin theme, phone and web layouts, WebAuthn sign-in, 15 min sessions, IP allow-list
- ☐ A1 to A5 screens; roles, permissions and the protected super admin
- ☐ Recovery flow end to end with the offline key; break-glass and handover server commands
- ☐ Hash-chained audit log with verify and export

S6 Security review and beta (22 Mar to 16 Apr)

- ☐ Self-review against OWASP MASVS and ASVS; OWASP ZAP scan of the staging API and admin
- ☐ Accessibility pass: TalkBack, axe, contrast, focus order
- ☐ Signed APK on GitHub Releases; web and admin live on free hosting; nightly encrypted backup
- ☐ Release checklist from the build plan complete

Testing gates on every pull request: crypto vectors and tamper tests; API tests against a Neon test branch; component stories and visual snapshots in all themes; an automated check that no secret, key or plaintext reaches logs, crash reports or analytics. Detox (Android) and Playwright (web) end-to-end runs cover sign-up, add, edit, copy, two-device sync and recovery, nightly and before each release.